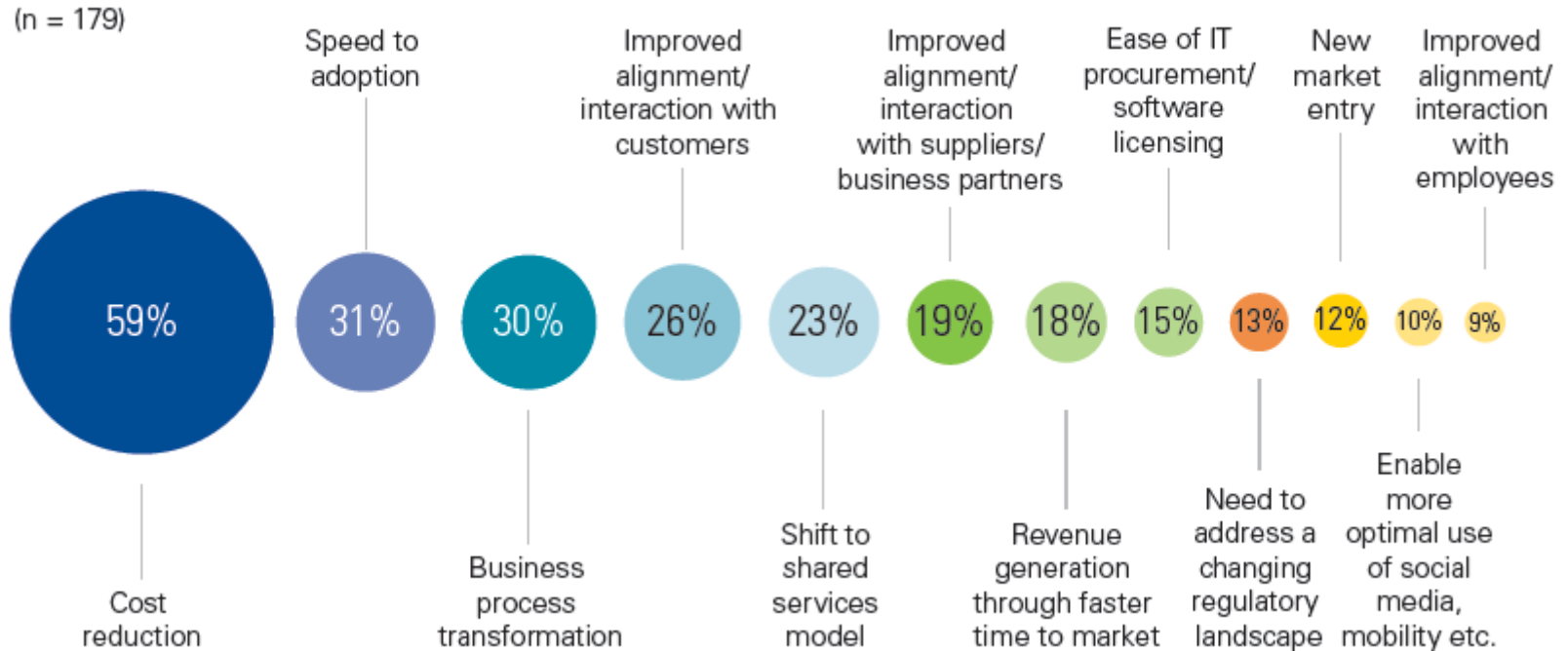


Security and Privacy in Cloud Computing

10 November 2025

Why do customers use the cloud?

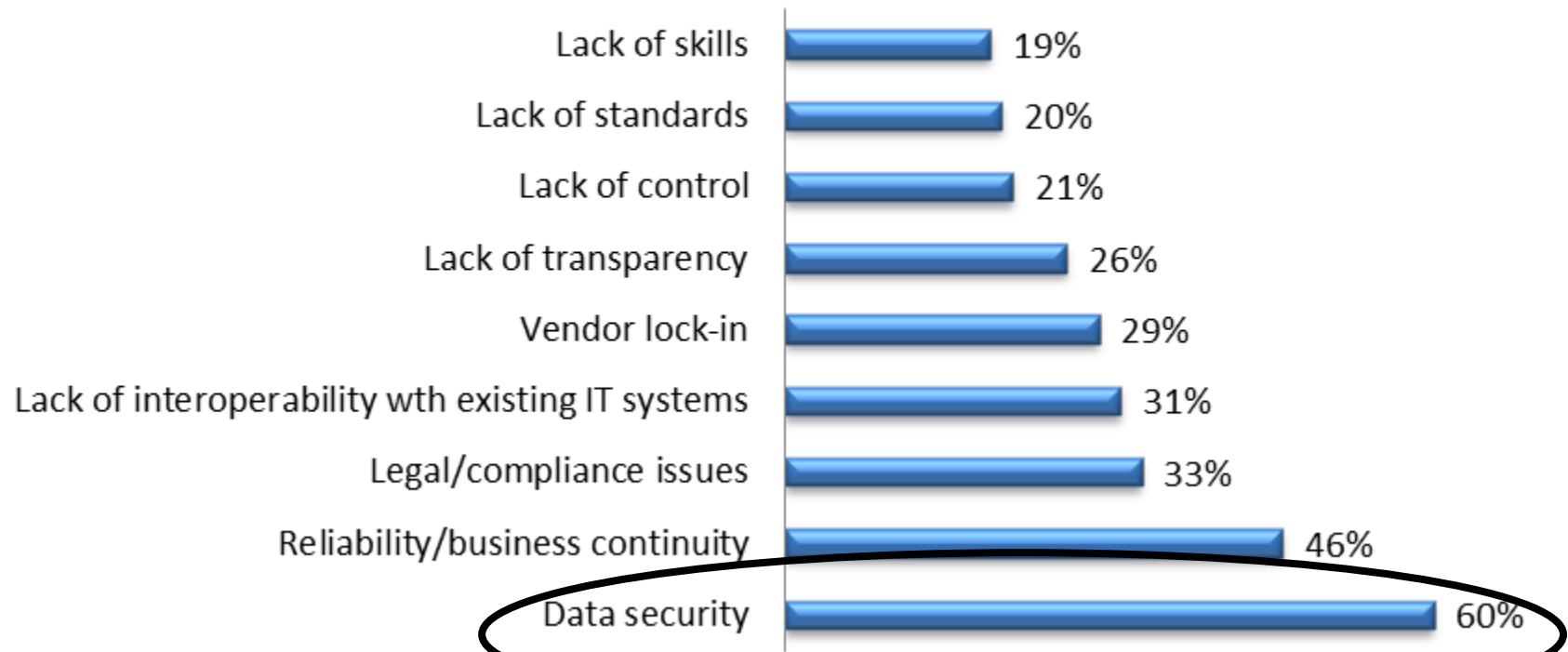


KPMG International's 2012 Global Cloud Provider Survey (n=179)

CHALLENGES

Cloud Computing: Concerns

Significant Concerns with Cloud Computing



Challenges in using the cloud

- Security
- Privacy
- Compliance

SECURITY PRIMER

Terminology: CIA Triad



wallarm



Terminology: CIA Triad

- **Confidentiality: Keeping Information Private**

- Confidentiality ensures that unauthorized individuals cannot gain access to data
- This means that only authorized users with proper access control measures—like [multifactor authentication \(MFA\)](#)—can see or manipulate personal data in a secure environment
- A lack of confidentiality puts organizations at risk of exposing sensitive information
- Whether it's strategic plans, customer details, or trade secrets, failing to maintain secrecy can result in hefty fines, reputational harm, and compromised consumer trust
- Just as important, ensuring confidentiality supports local governance requirements in managing and sharing confidential information across agencies that require strict oversight

Terminology: CIA Triad

- **Availability: Access When Needed**

- The availability pillar emphasizes that users should have timely access to information whenever they need it. Even if data is well-protected and accurate, it loses value when not readily accessible to those who rely on it for decision-making or daily tasks.
- Ensuring availability involves regularly maintaining computer systems, conducting backups, and deploying redundancies to keep the digital world running smoothly. Especially in today's 24/7 global economy, downtime can have serious implications, ranging from financial setbacks to public frustration. Entities of all sizes must prioritize stability, designing their infrastructure so that data and critical applications remain reachable under normal circumstances and during unforeseen events.

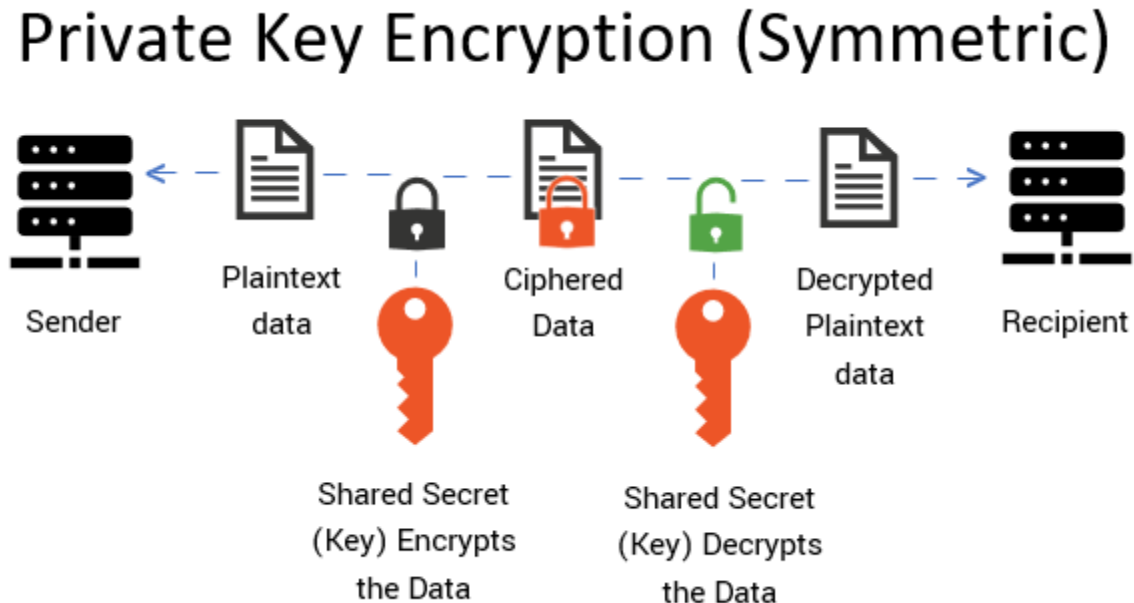
Terminology: CIA Triad

- **Integrity: Ensuring Information Accuracy**

- Integrity focuses on the accuracy and reliability of digital information from the moment it's created to the final stage of its lifecycle. By protecting data from unauthorized changes—whether accidental or malicious—organizations ensure that the information remains truthful and useful.
- When integrity is compromised, false records, tainted analytics, or misleading reports can derail strategic decisions. This risk is amplified in scenarios involving operating system updates, intricate databases, or large-scale applications that rely on consistent inputs. An intentional or unintentional alteration can disrupt operations and erode trust with both internal and external stakeholders.

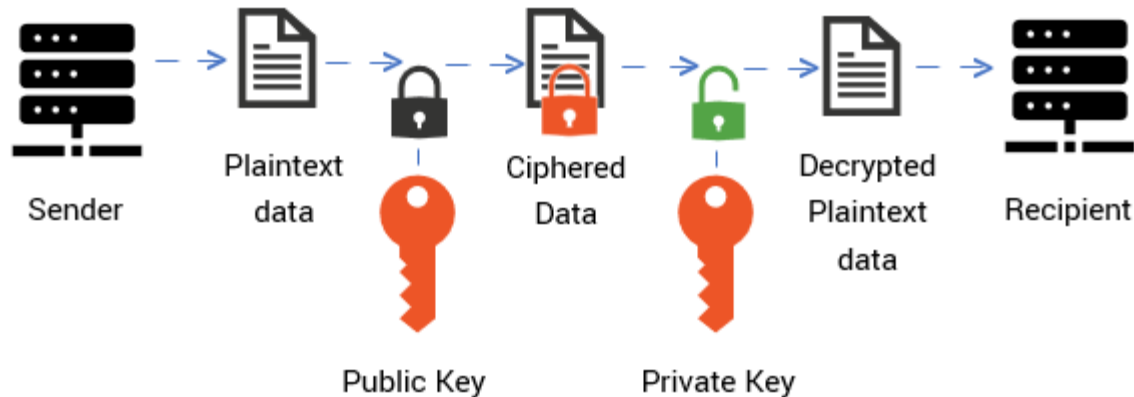
Public Key & Private Key Encryption

Private Key (Symmetric) Encryption

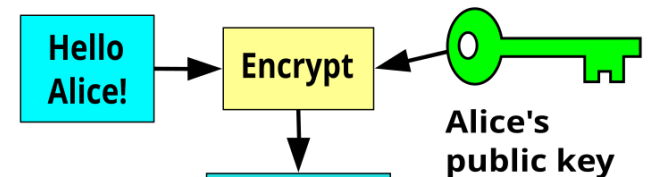


Public Key (Asymmetric) Encryption

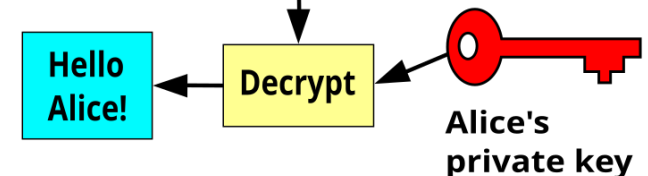
Public Key Encryption (Asymmetric)



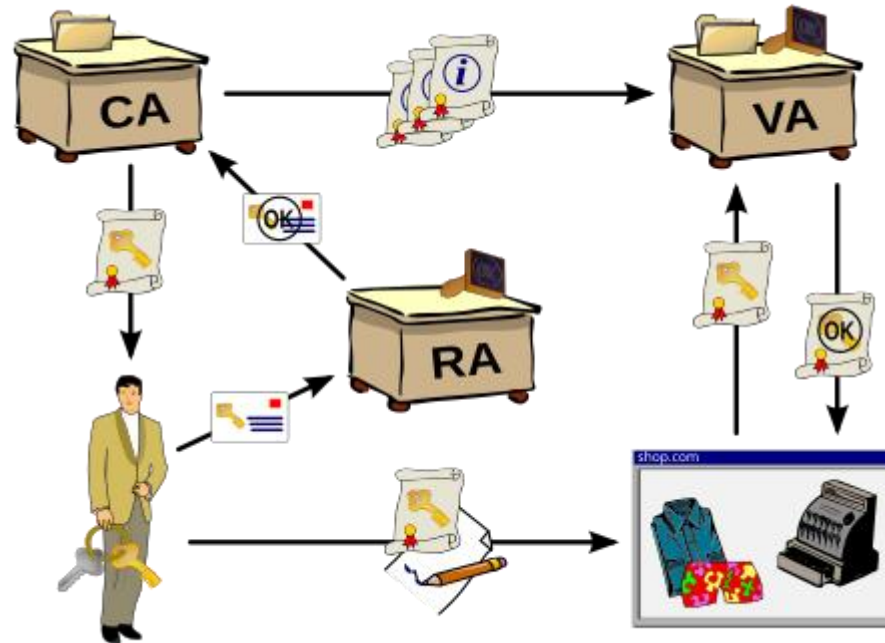
Bob



Alice



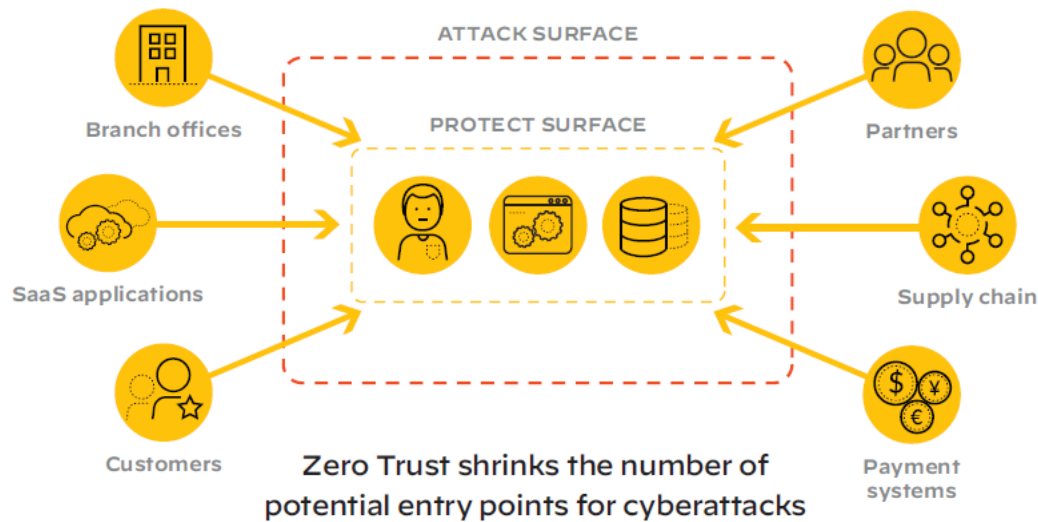
Public Key Infrastructure (PKI)



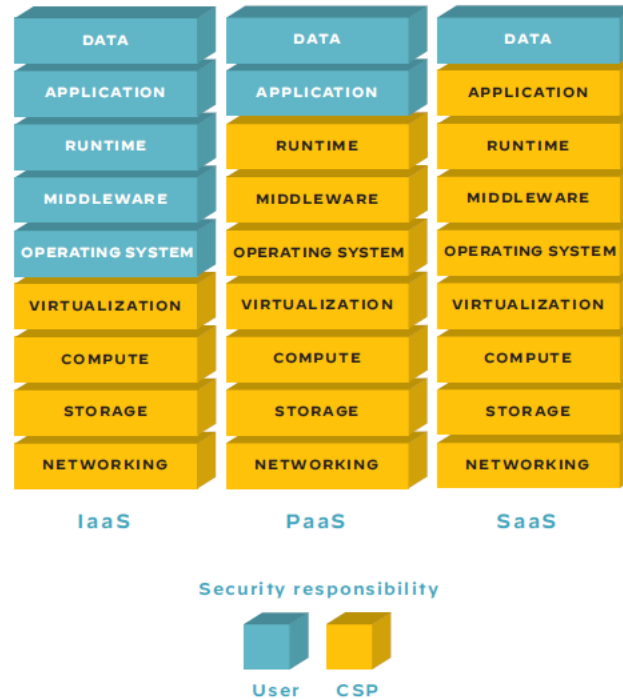
RA: Registration Authority
VA: Validation Authority

Bringing Zero Trust Security to the Public Cloud

Never Trust, Always Verify!

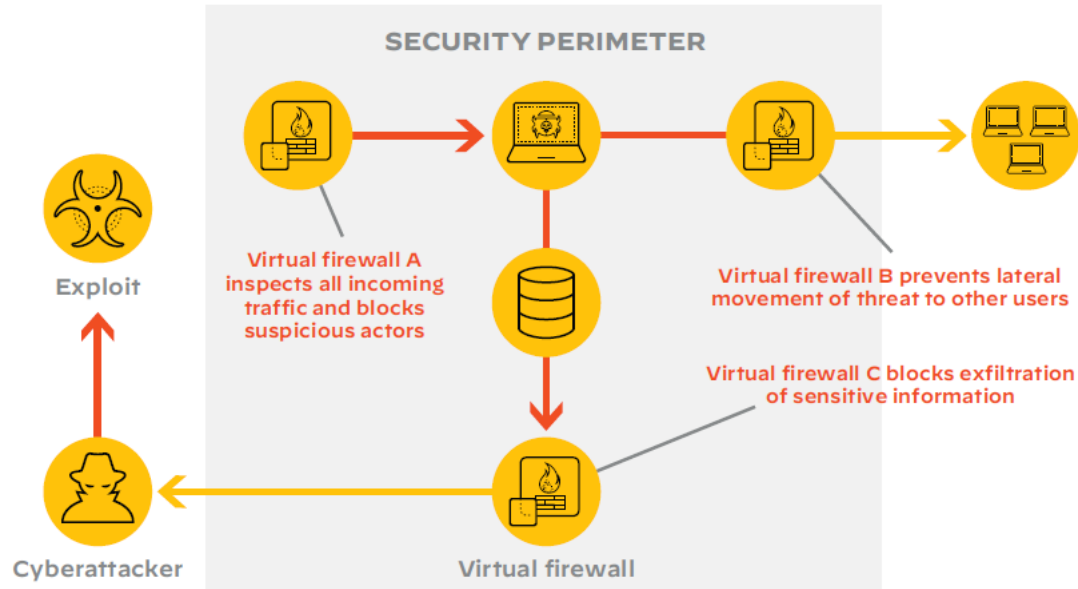


Flavours of Public Cloud



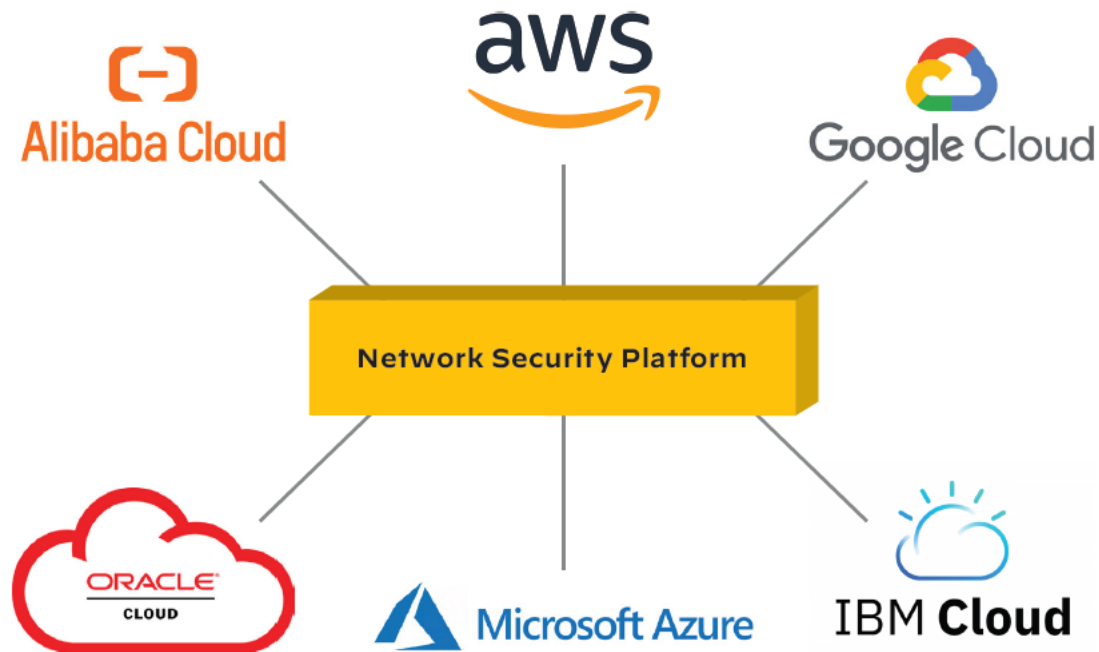
Security models for the three flavors
of public cloud

Virtual Firewalls: Essential for Public Cloud

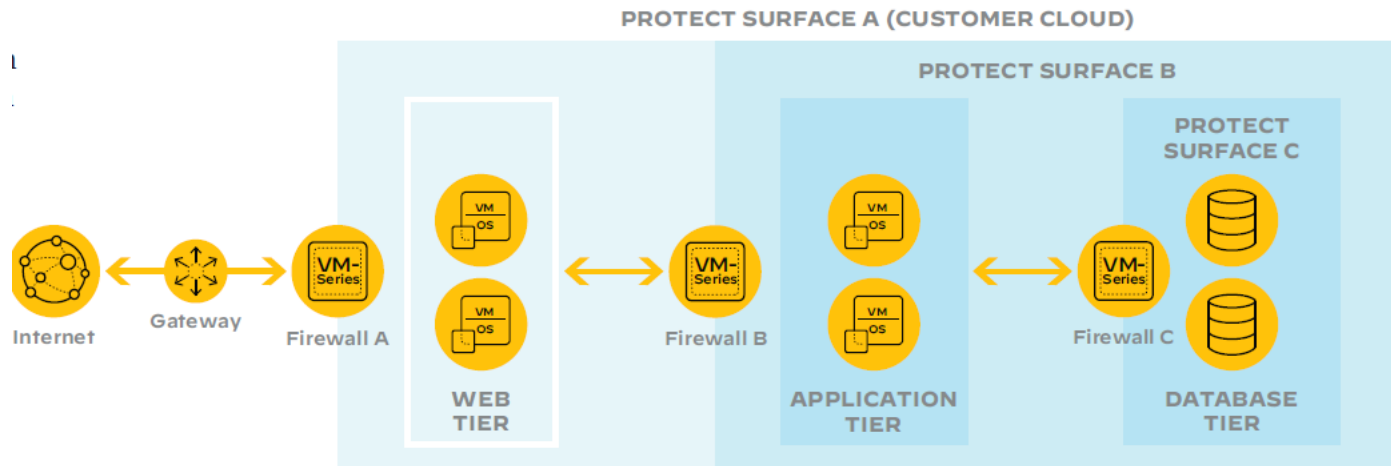


Virtual firewalls offer defense-in-depth protection against cyberthreats

Network Security Platform



Zero Trust Security for Defense in Depth



Multitiered protection of public cloud applications
using VM-Series virtual firewalls

Attack Surfaces and Attack Vectors

- An attack surface is the sum of all potential vulnerabilities in a system or network that an attacker could exploit
- An attack vector is a specific method used to exploit one of those vulnerabilities within the attack surface

Attack Surfaces in Cloud Computing

1. Management and Identity
2. Compute and Virtualization
3. Containers and Orchestration
4. Serverless (FaaS) Environments
- 5. Networking and Connectivity**
6. Storage and Databases
7. Data in Transit and at Rest
8. DevOps and CI/CD Pipelines
9. Infrastructure as Code (IaC)
10. Third-Party and Supply Chain Integrations
11. Monitoring, Logging, and Telemetry
12. Multitenancy and Shared Resources
13. Physical and Hardware Infrastructure
14. Backup and Disaster Recovery Systems
15. Client and Endpoint Devices



Example of an Attack Vector in Cloud Computing

Networking & Connectivity

- Misconfigured Network ACLs
- Exposed Management Endpoints
- Unencrypted or Weakly Encrypted Traffic
- Man-in-the-Middle (MITM) Attacks
- DNS Hijacking or Poisoning
- BGP Hijacking and Route Leaks
- ARP Spoofing and Poisoning
- VPC/VNet Peering Misconfigurations
- Unprotected VPN Endpoints
- Weak or Leaked Network Appliance Credentials
- API Gateway or Load Balancer Abuse
- DDoS and Reflection Amplification Attacks
- Lateral Movement via Flat Networks
- Inter-Region or Cross-Zone Data Path Interception
- Misconfigured NAT or Gateway Rules
- Packet Injection or Replay Attacks
- Network-Based Side-Channel or Timing Attacks
- Router or Switch Firmware Compromise
- Insufficient Network Logging and Monitoring
- Exposure of Internal Services via Public IPs

Attack Surfaces and Attack Vectors in Cloud Computing

1. API / Management Interfaces

Surface: Cloud provider APIs, web consoles, CLI tools, management planes

Vectors: Credential theft, API key leakage, brute-force, privilege escalation, session hijacking

Examples: Compromised API key used to spin up VMs or exfiltrate data

Attack Surfaces and Attack Vectors in Cloud Computing

2. Identity and Access Management (IAM)

Surface: User accounts, roles, permissions, federation (SSO/OAuth)

Vectors: Misconfiguration (excessive permissions), credential stuffing, token theft, broken auth flows

Examples: Overly-broad IAM role used to access sensitive buckets

3. Virtualization & Hypervisor Layer

Surface: Hypervisors, VM isolation, host OS

Vectors: VM escape, side-channel attacks, hypervisor vulnerabilities, malicious guest VM

Examples: Escape from VM to host to access other tenants' VMs

Attack Surfaces and Attack Vectors in Cloud Computing

4. Network & Virtual Network Configurations

Surface: VPCs, subnets, ACLs, security groups, VPNs, peering.

Vectors: Misconfigured security groups, open ports, lateral movement, DNS hijacking, BGP hijack.

Examples: Security group allowing 0.0.0.0:22 leading to brute-force SSH attacks

Attack Surfaces and Attack Vectors in Cloud Computing

5. Storage & Data Services

Surface: Object stores (S3/Azure Blob), block storage, databases, backups.

Vectors: Publicly exposed buckets, insecure access controls, SQL injection, data exfiltration, snapshot theft.

Examples: Public S3 bucket containing customer PII.

6. Data in Transit / Network Traffic

Surface: Inter-service communication, APIs, client-server links.

Vectors: MITM (man-in-the-middle), TLS/SSL downgrade, weak cipher suites, unsecured endpoints.

Examples: Intercepted API traffic due to misconfigured TLS

Attack Surfaces and Attack Vectors in Cloud Computing

8. Data at Rest / Encryption

Surface: Encrypted volumes, database encryption, key management.

Vectors: Poor key management, leaked keys, weak encryption modes, compromised KMS access.

Examples: Attacker gaining access to KMS role and decrypting database snapshots.

Mitigation Summary

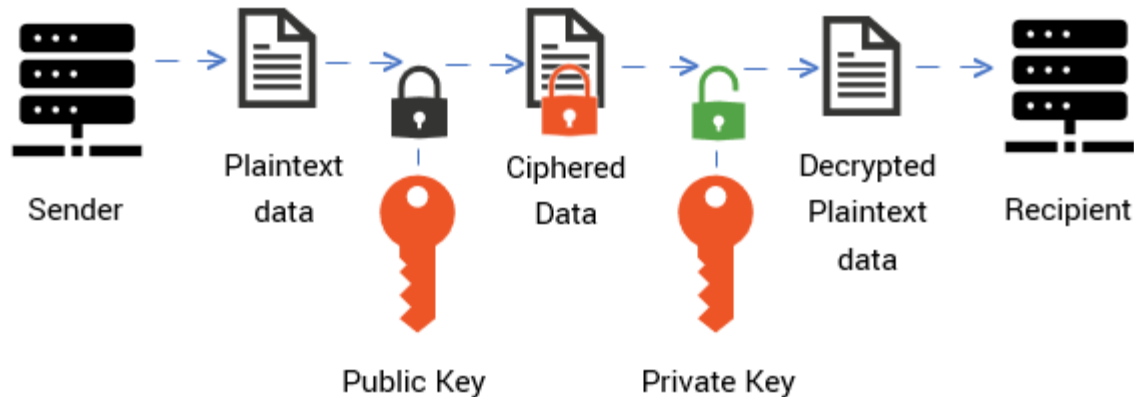
- **Least privilege Identity & Access Management (IAM)** and strong auth (Multi-Factor Authentication, short-lived tokens)
- **Harden APIs & Consoles** (rate-limiting, logging, Web Application Firewall (WAF))
- **Secure CI/CD and Infrastructure as Code (IaC)**: secrets management, code signing, image scanning
- **Encrypt data** in transit and at rest; protect keys (separate KMS roles)
- **Network segmentation & secure defaults**: restrict security groups, use private subnets
- **Scan and vet third-party code/images**; use registries with provenance and signing
- **Monitor and alert** on anomalous activity; retain immutable logs
- **Patch and isolate virtualization/container layers**, and follow supply-chain best practices
- **Regular pentesting, red-teaming, and threat modeling** tailored to cloud architecture

END OF CLOUD SECURITY PRIMER

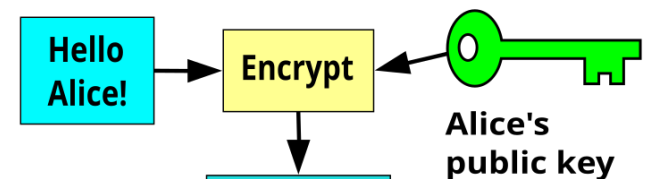
PRIMER ON PUBLIC KEY ENCRYPTION

Public Key (Asymmetric) Encryption

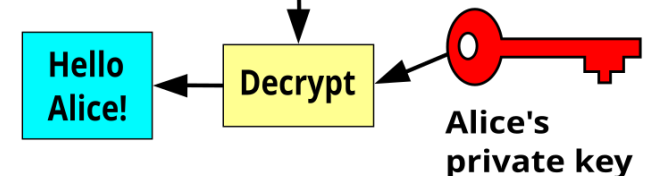
Public Key Encryption (Asymmetric)



Bob

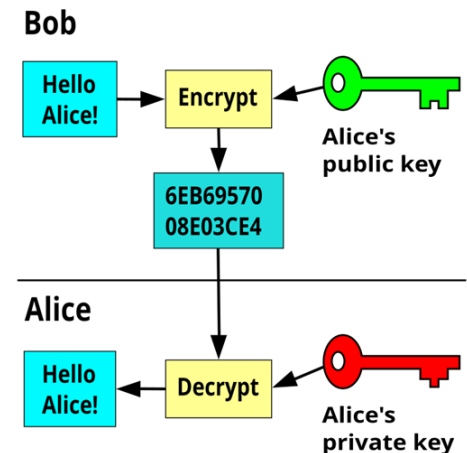


Alice



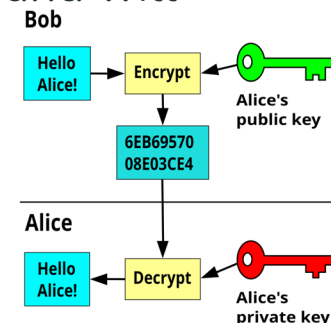
The Rivest-Shamir-Adleman (RSA) Algorithm

- RSA Algorithm is based on **factorization** of large number and **modular arithmetic** for encrypting and decrypting data. It consists of three main stages:
 1. **Key Generation:** Creating Public and Private Keys
 2. **Encryption:** Sender encrypts the data using Public Key to get **cipher text**
 3. **Decryption:** Decrypting the **cipher text** using Private Key to get the original data



RSA Algorithm

- Choose two large prime numbers, say p and q . These prime numbers should be kept secret.
- Calculate the product of primes, $n = p * q$. This product is part of the public as well as the private key.
- Calculate [Euler Totient Function](#) $\Phi(n)$ as $\Phi(n) = \Phi(p * q) = \Phi(p) * \Phi(q) = (p - 1) * (q - 1)$.
- Choose encryption exponent e , such that
 - $1 < e < \Phi(n)$, and
 - $\gcd(e, \Phi(n)) = 1$, that is e should be co-prime with $\Phi(n)$.
- Calculate decryption exponent d , such that
 - $(d * e) \equiv 1 \pmod{\Phi(n)}$, that is d is [modular multiplicative inverse](#) of $e \pmod{\Phi(n)}$. Some common methods to calculate multiplicative inverse are: [Extended Euclidean Algorithm](#), [Fermat's Little Theorem](#), etc.
 - We can have multiple values of d satisfying $(d * e) \equiv 1 \pmod{\Phi(n)}$ but it does not matter which value we choose as all of them are valid keys and will result into same message on decryption.
- **Public Key = (n, e)** and the **Private Key = (n, d)** .



RSA Algorithm

2. Encryption

To encrypt a message **M**, it is first converted to numerical representation using ASCII and other encoding schemes

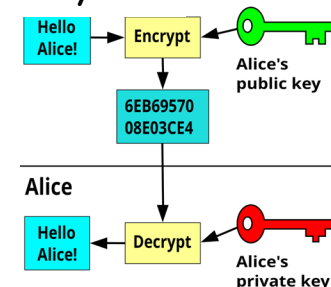
Now, use the public key (n, e) to encrypt the message and get the cipher text using the formula:

$C = M^e \bmod n$, where C is the Cipher text and e and n are parts of public key

3. Decryption

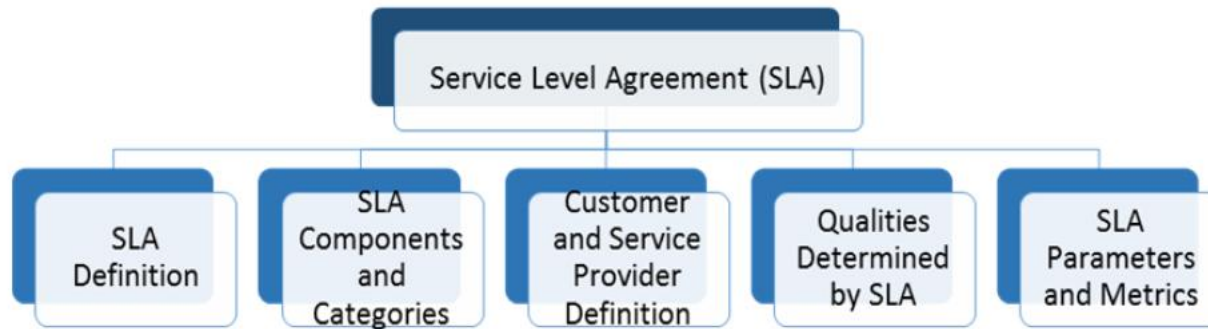
To decrypt the cipher text **C**, use the private key (n, d) and get the original data using the formula:

$M = C^d \bmod n$, where M is the message and d and n are parts of private key.

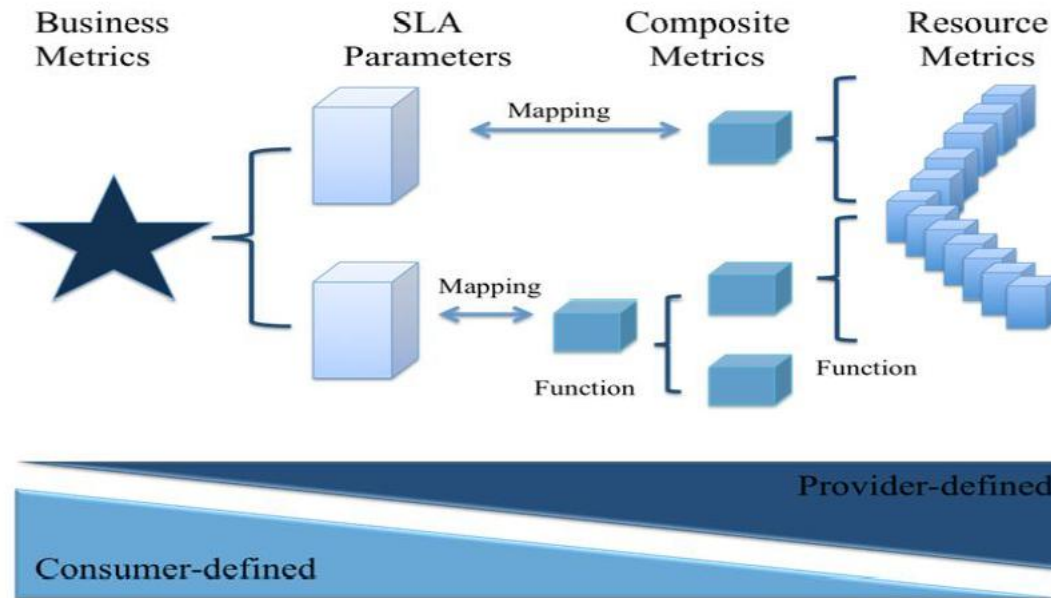


SERVICE LEVEL AGREEMENT (SLA) IN CLOUD COMPUTING

Service Level Agreements (SLA) Concept



Aggregated Business Metrics, SLA Parameters and Metrics through Different Organizations



SLA General Terms

Parameter	Description
Monitoring	Who do the monitoring and what method of monitoring
Billing	Cost of service and how can be calculated
Security	Issues like cryptography, authentication, and authorization are main requirements for cloud users
Networking	The number of IPs, throughput, and load balancing
Privacy	How the data will be stored and transferred
Support service	Cloud providers should clearly define the methods of help and support
Local and international policies	The policy standards that providers follow

Example of SLA Metrics for IaaS

Parameter	Description
CPU capacity	CPU speed for VM (Virtual Machine)
Memory size	Cash memory size for VM
Boot time	Time for MV to be ready for use
Storage	Storage size of data for short or long term of contract
Scale up	Maximum of VMs for one user
Scale down	Minimum number of VMs for one user
Scale up time	Time to increase a specific number of VMs
Scale down time	Time to decrease a specific number of VMs
Auto scaling	Boolean value for auto scaling feature
Max number can be configured on physical server	Maximum number of VMs that can be run on individual server
Availability	Uptime of service in specific time
Response time	Time to complete and receive the process

Example of SLA Metrics for PaaS

Parameter	Description
Integration	Integration with e-services and other platforms.
Scalability	Degree of use with a large number of online users
Pay as you go billing	Charging based on resources or time of service
Environments of deployment	Supporting offline and cloud systems
Browsers	Firefox, Explorer, etc.
Number of developers	How many developers can access to the platform

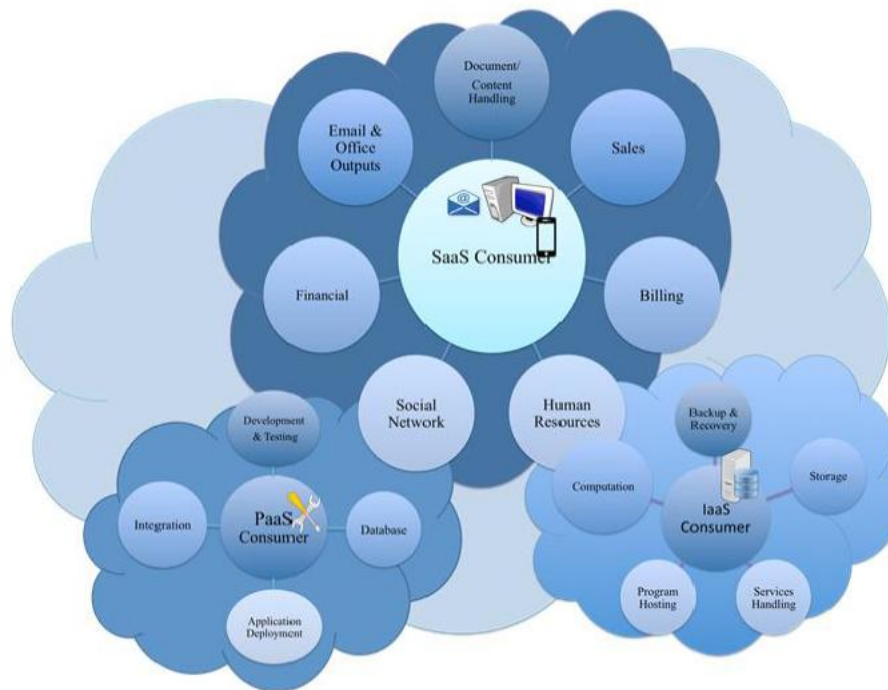
Example of SLA Metrics for SaaS

Parameter	Description
Reliability	Ability to keep operating in most cases
Usability	Easy built-in user interfaces
Scalability	Used with individual or large organizations
Availability	Uptime of software for users in specific time
Customizability	Flexible to use with different types of users

Example of SLA Metrics for Storage as a Service

Parameter	Description
Geographic location	Available zones in which data are stored
Scalability	Ability to increase or decrease storage space
Storage space	Quantity of units of data storage
Storage billing	How the cost of storage is calculated
Security	Cryptography for storage, transferring data, authentication, and authorization
Privacy	How the data will be stored and transferred
Backup	How and where images of data are stored
Recovery	Ability to recover data in disasters or failures
System throughput	Amount of data that can be retrieved from system in a specific unit of time
Transferring bandwidth	The capacity of communication channels
Data life cycle management	Managing data in data centers, and using network infrastructure

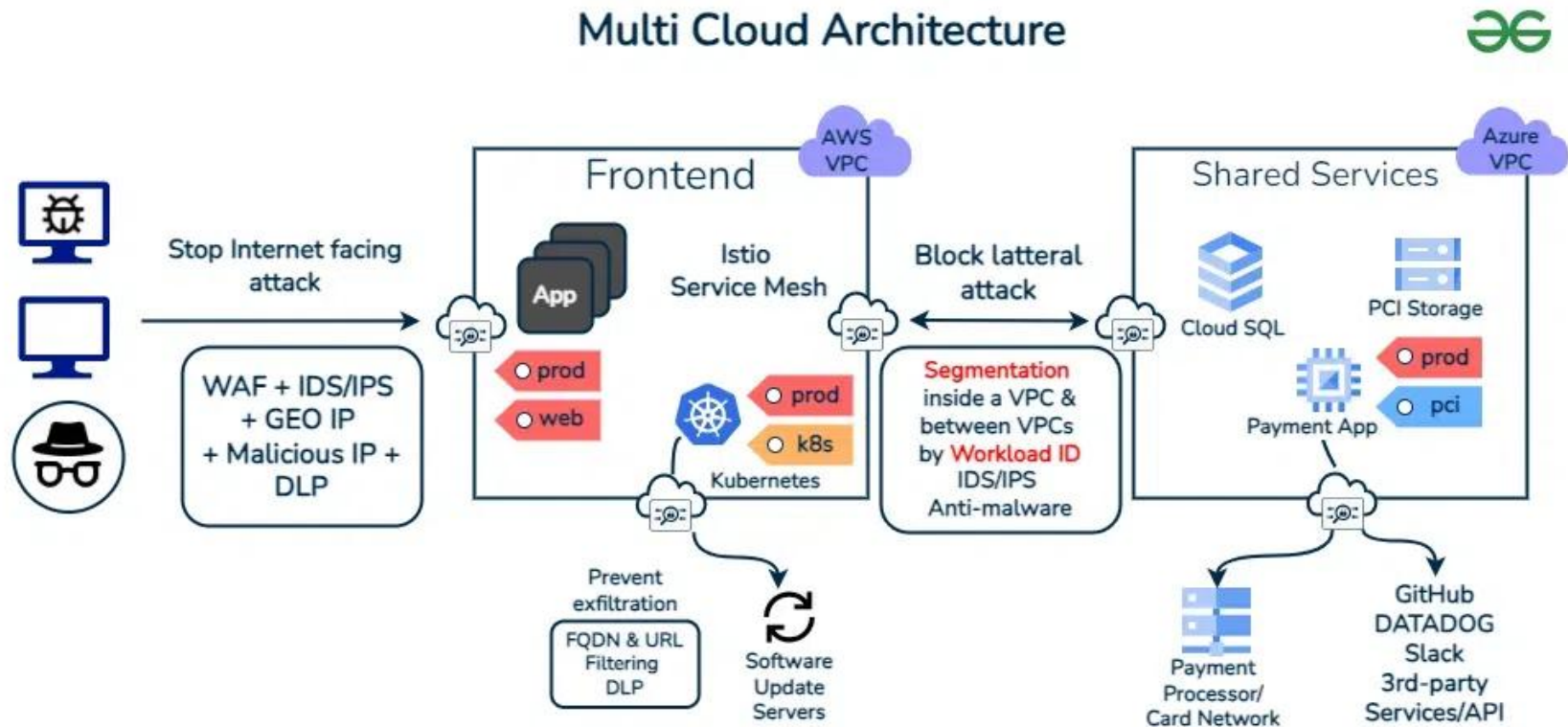
Several Cloud Services Accessible to a Cloud Client



What is Multi Cloud?

- *Multi-cloud is the use of two or more cloud providers together, they might be public, private or a mix of both to achieve the organization's goals*
- Basically, it is the use of various types of cloud operators to have more features and increase their organization's flexibility which also covers the disadvantages of the individual platforms
- Companies prefer multi-cloud environments as they can distribute computing resources and minimize the risk of downtime and data loss
- Multi cloud allows one organization to use most appropriate and most beneficial cloud options based on their business requirement which may be public or private cloud for each separate application

Multi Cloud Architecture



Why use a Multi Cloud Strategy?

- **Flexibility and Redundancy**

- It offers the flexibility to choose the best services from different cloud providers ensuring redundancy and reducing risk of downtime

- **Vendor Lock-in Mitigation**

- It helps organizations to avoid dependency on single cloud provider. It helps to avoid the mitigating risks associated with vendor lock-in and negotiation leverage

- **Optimized Performance**

- On using multiple cloud providers facilitates in optimizing the workload based on specific requirements such as geographical locations, scalability and cost

- **Compliance and Data Sovereignty**

- It facilitates compliance with data residency regulations by enabling organizations to store data in multiple geographic regions as required

Disadvantages of a Multi Cloud Strategy?

- **Provider Selection**
- **Integration Complexity**
- **Location and Pricing Optimization**
- **Cost estimation, Optimization and Reporting**
 - Getting a multi cloud provider might sound easy and cheap but estimating the costs and consolidating it is tough
- **Security Risks**
 - Handling a multi cloud environment is difficult because they have to manage all individual providers and their respective security protocols which increases complexity in maintaining consistent security standards

Open Areas in Cloud Computing

- DevOps
- Mobile Cloud Computing
- Green Cloud Computing
- Edge Computing
- Multi-Cloud Management
- Blockchain in Cloud Computing
- Cloud based IoT
- ...